

PARTE 1 — HISTORIA TÉCNICA DEL INCIDENTE

¿Quién fue el atacante?

El atacante fue un ex empleado del departamento de informática de la empresa. Tenía conocimientos básicos de redes y sabía cómo estaba estructurada la infraestructura porque había trabajado allí durante seis meses.

No se trata de un hacker avanzado, sino de una persona con conocimientos técnicos medios y acceso previo a información interna.

¿Qué vulnerabilidad aprovechó?

Aprovechó varias debilidades:

- El servidor FTP permitía autenticación sin cifrado.
- Las contraseñas eran débiles.
- No había segmentación de red (todo estaba en la misma VLAN).
- El router no tenía listas de control de acceso (ACL).

¿Cómo entró?

1. Desde el exterior realizó un escaneo de puertos.
2. Detectó que el puerto 21 (FTP) estaba abierto.
3. Intentó acceder con credenciales antiguas que todavía seguían activas.
4. Como su cuenta no había sido eliminada tras abandonar la empresa, pudo iniciar sesión.

¿Qué hizo exactamente?

Una vez dentro:

- Descargó documentos internos (afectando a la confidencialidad).
- Modificó un archivo de configuración del servidor web (afectando a la integridad).
- Subió archivos de gran tamaño repetidamente hasta saturar el almacenamiento (afectando a la disponibilidad).

¿Qué error humano lo permitió?

- No eliminar la cuenta del ex empleado.
- Utilizar contraseñas simples.
- No revisar los accesos tras su salida de la empresa.

¿Qué fallo técnico lo permitió?

- Uso de FTP en lugar de SFTP.

- Ausencia de VLAN separadas.
- Falta de ACL en el router.
- No existía política de bloqueo tras intentos fallidos.
- No se revisaban los logs del sistema.

¿Qué impacto tuvo?

- Confidencialidad: robo de información interna.
- Integridad: modificación de archivos del servidor.
- Disponibilidad: caída temporal del servicio.

La empresa tuvo que restaurar copias de seguridad y cambiar todas las credenciales.

PARTE 2 — DEMOSTRACIÓN DEL FALLO EN PACKET TRACER

Mala configuración que permitió el incidente

- Red sin segmentación (todo en VLAN 1).
- Servidor FTP activo.
- Puerto 21 abierto en el router.
- Sin ACL configuradas.
- Cuenta de usuario antigua activa.

Cómo podría producirse en Packet Tracer

1. Comprobación del puerto abierto

Si conecta, significa que el puerto FTP está accesible desde fuera.

2. Acceso al servidor FTP

Se introducen las credenciales antiguas.

Si el usuario sigue activo y la contraseña es débil, el acceso se concede.

3. Comprobación de ausencia de ACL en el router

Si no aparece ninguna access-list configurada, significa que no hay restricciones de acceso.

4. Red sin segmentación

Si solo aparece VLAN 1, toda la red está en el mismo dominio de broadcast, lo que facilita el movimiento lateral.

PARTE 3 — REDISEÑO MEJORADO

1. Separación por VLAN

- VLAN 10: Administración
- VLAN 20: Servidores
- VLAN 30: Invitados

Qué problema soluciona: evita que todos los equipos estén en la misma red.

Qué riesgo reduce: movimiento lateral del atacante.

Qué pasaría si no se aplica: cualquier equipo comprometido podría acceder directamente a los servidores.

2. Configuración de ACL en el router

Qué problema soluciona: controla qué redes pueden acceder a los servidores.

Qué riesgo reduce: accesos no autorizados.

Qué pasaría si no se aplica: el servidor seguirá accesible desde cualquier red.

3. Sustituir FTP por SFTP

FTP transmite datos en texto plano.

SFTP cifra la comunicación mediante SSH.

Qué problema soluciona: evita la interceptación de credenciales.

Qué riesgo reduce: robo de contraseñas y datos.

Qué pasaría si no se aplica: las credenciales podrían capturarse fácilmente.

4. Activar Port-Security en switches

Qué problema soluciona: impide conectar dispositivos no autorizados.

Qué riesgo reduce: intrusiones físicas.

Qué pasaría si no se aplica: cualquier persona podría conectar un dispositivo y acceder a la red.

5. Política de bloqueo tras intentos fallidos

- Bloqueo tras 3 intentos fallidos.
- Contraseñas de mínimo 10 caracteres.

Qué problema soluciona: ataques de fuerza bruta.

Qué riesgo reduce: compromiso de cuentas.

Qué pasaría si no se aplica: un atacante podría probar múltiples combinaciones sin límite.

6. Hardening del router

- Cambiar contraseñas por defecto.
- Desactivar servicios innecesarios.

- Usar SSH en lugar de Telnet.

Qué problema soluciona: accesos inseguros al router.

Qué riesgo reduce: control total de la red por parte de un atacante.

Qué pasaría si no se aplica: el router podría ser comprometido fácilmente.